Action plan

Domain Care Access Navigator - IAM & GRC
Perimeter Mock EHR - Workforce Access Governance
Assessment Healthcare IAM - HIPAA Security Rule Access Controls Audit — 2.0
Framework NIST - NIST SP-800-66 rev2 (HIPAA)

Associated applied controls, separated by status and sorted by ETA. 18 in total.

To do (1)

Name	Description	Category	Owner	ETA	Matching items
Security logs are kept 12 months	Security logs are kept 12 months Area: Monitoring / retention HIPAA: 164.316(b)(2) (policy); 164.312(b) NIST CSF 2.0: PR.PS-04 NIST SP 800-53 r5: AU-11 ISO 27001:2022: A.8.15 PCI DSS 4.0.1: 10.5.1 Risks: R03 Evidence: Compliance E-LOG-01 Test: Audit LOG-01 test 3 Test result (2026-11-03): FAIL	Technical	akchrao@gmail.com	-	2. Retain Documentation for at Least Six Years

In progress (6)

Name	Description	Category	Owner	ETA	Matching items
ePHI and credentials are encrypted in transit (TLS 1.2+)	ePHI and credentials are encrypted in transit (TLS 1.2+) Area: Data protection HIPAA: 164.312(e)(1), (e)(2)(ii) NIST CSF 2.0: PR.DS-02 NIST SP 800-53 r5: SC-8, SC-8(1) ISO 27001:2022: A.8.24 PCI DSS 4.0.1: 4.2.1 Risks: R03 Evidence: Compliance E-ENC-01 Test: Audit ENC-01 tests 1-4 Test result (2026-11-03): PASS (Azure); EXCEPTION (IdP)	Technical	akchrao@gmail.com	-	4. Implement Encryption
Privileged and cardholder-data users pass MFA	Privileged and cardholder-data users pass MFA Area: Authentication	Technical	akchrao@gmail.com	-	3. Select and Implement Authentication Options

Name	Description	Category	Owner	ETA	Matching items
	HIPAA: 164.312(d) NIST CSF 2.0: PR.AA-03 NIST SP 800-53 r5: IA-2(1), IA-2(2) ISO 27001:2022: A.8.5 PCI DSS 4.0.1: 8.4.1, 8.4.2 Risks: R03 Evidence: EV-13 verify (MFA_REQUIRED) Test: W5 verify; TC-03 Test result (2026-11-03): PASS				
Privileged access is approved, limited and monitored	Privileged access is approved, limited and monitored Area: IAM / PAM HIPAA: 164.308(a)(4)(ii)(B) NIST CSF 2.0: PR.AA-05 NIST SP 800-53 r5: AC-2(7), AC-6(5), AC-6(9) ISO 27001:2022: A.8.2 PCI DSS 4.0.1: 7.2.2, 8.2.2 Risks: R04 Evidence: Privileged access matrix; TC-07 Test: TC-07 Test result (2026-11-03): PASS	Technical	akchrao@gmail.com	-	2. Implement Policies and Procedures for Authorizing Access 7. Establish an Emergency Access Procedure
Automated Keycloak Leaver Deprovisioning	Implement automated deprovisioning between Microsoft Entra ID and Keycloak so that workforce termination triggers the timely disablement of corresponding Keycloak accounts, revocation of active sessions, and verification of application access removal. Implement reconciliation and alerting to detect accounts that remain enabled after termination. This planned control addresses the deprovisioning gap identified during Jeevan Smith's termination (TERM-2026-0301). Implementation and effectiveness testing are pending. Remediation Validation Plan – R02 Objective: Verify that terminating a workforce member in Microsoft Entra ID automatically revokes their Keycloak access and prevents access to the Mock EHR application. Test 1 – Account deprovisioning: Disable a synthetic employee account in Entra ID. Verify that the corresponding Keycloak account is automatically disabled within the organization's	Technical	akchrao@gmail.com	-	5. Establish Termination Procedures

Name	Description	Category	Owner	ETA	Matching items
	defined termination SLA. Test 2 – Session revocation: Confirm that active Keycloak sessions are terminated or invalidated and that the terminated employee cannot reuse an existing application session. Test 3 – Access verification: Attempt to authenticate and access the Mock EHR using the terminated test account. Verify that access is denied. Test 4 – Audit logging: Confirm that termination, account disablement, session revocation, and verification activities are logged with timestamps. Test 5 – Monitoring: Confirm that reconciliation or alerting identifies accounts that remain enabled after termination. Acceptance criteria: All five tests must pass, with supporting screenshots and log evidence. Any failure requires corrective action and retesting. Related finding: CAN-FIND-001 Related risk: R02 Status: Planned – Implementation and validation pending.				
Access is reviewed periodically and findings are remediated	Access is reviewed periodically and findings are remediated Area: IAM / GRC HIPAA: 164.308(a)(4)(ii)(C); 164.308(a)(1)(ii)(D) NIST CSF 2.0: PR.AA-05, ID.IM-01 NIST SP 800-53 r5: AC-2(j) ISO 27001:2022: A.5.18 PCI DSS 4.0.1: 7.2.4, 7.2.5.1 Risks: R01, R02 Evidence: access_review_*.csv; TC-09 Test: TC-09 Test result (2026-11-03): PASS	Process	akchrao@gmail.com	-	7. Develop and Deploy the Information System Activity Review Process 4. Evaluate Existing Security Measures Related to Access Controls 6. Review and Update Access for Users and Processes
Vendor access is sponsored, time-boxed and removed at expiry	Vendor access is sponsored, time-boxed and removed at expiry Area: Third-party access HIPAA: 164.308(b)(1); 164.314(a) NIST CSF 2.0: GV.SC-07, PR.AA-05 NIST SP 800-53 r5: AC-2(2), PS-7 ISO 27001:2022: A.5.19, A.5.20 PCI DSS 4.0.1: 8.2.7	Process	akchrao@gmail.com	-	1. Identify Entities that are Business Associates Under the HIPAA Security Rule

Name	Description	Category	Owner	ETA	Matching items
	Risks: R05 Evidence: Service/vendor identity register; TC-08 Test: TC-08 Test result (2026-11-03): PASS				

Active (11)

Name	Description	Category	Owner	ETA	Matching items
Security-relevant identity events are logged	Security-relevant identity events are logged Area: Monitoring HIPAA: 164.312(b) NIST CSF 2.0: DE.CM-03, PR.PS-04 NIST SP 800-53 r5: AU-2, AU-3, AU-12 ISO 27001:2022: A.8.15 PCI DSS 4.0.1: 10.2.1 Risks: R03, R04 Evidence: keycloak_login_events.csv; Wazuh (IR lab) Test: W5 detect run Test result (2026-11-03): PASS	Technical	akchrao@gmail.com	-	9. Implement the Information System Activity Review and Audit Process 1. Determine the Activities that Will Be Tracked or Audited
Lockout after repeated failures; strong password standard	Lockout after repeated failures; strong password standard Area: Authentication HIPAA: 164.308(a)(5)(ii)(D) NIST CSF 2.0: PR.AA-03 NIST SP 800-53 r5: AC-7, IA-5(1) ISO 27001:2022: A.5.17, A.8.5 PCI DSS 4.0.1: 8.3.4, 8.3.6, 8.3.7 Risks: R03 Evidence: EV-13 lockout + password tests Test: W5 verify; TC-05 Test result (2026-11-03): PASS	Technical	akchrao@gmail.com	-	Implementation Specification (Log-in Monitoring) Implementation Specification (Password Management) 3. Select and Implement Authentication Options
Security risks are identified, scored and treated	Security risks are identified, scored and treated Area: GRC HIPAA: 164.308(a)(1)(ii)(A)-(B) NIST CSF 2.0: ID.RA-05, ID.RA-06 NIST SP 800-53 r5: RA-3, PM-9 ISO 27001:2022: Clause 6.1.2, 6.1.3 PCI DSS 4.0.1: 12.3.1 Risks: R01-R05 Evidence: Risk register R01-R05 (Risk Management 1)	Process	akchrao@gmail.com	-	2. Conduct Risk Assessment 3. Implement a Risk Management Program

Name	Description	Category	Owner	ETA	Matching items
	Test: Register review Test result (2026-11-03): PASS				
Users receive only the access their job requires (RBAC, least privilege)	Users receive only the access their job requires (RBAC, least privilege) Area: IAM / RBAC HIPAA: 164.308(a)(4)(ii)(B); 164.312(a)(1) NIST CSF 2.0: PR.AA-05 NIST SP 800-53 r5: AC-2, AC-3, AC-6 ISO 27001:2022: A.5.15, A.5.18 PCI DSS 4.0.1: 7.2.1, 7.2.2 Risks: R01 Evidence: EV-13 access reviews; TC-01 Test: TC-01; audit AC-01 tests 1-2 Test result (2026-11-03): PASS	Technical	akchrao@gmail.com	-	2. Implement Policies and Procedures for Authorizing Access 3. Implement Policies and Procedures for Access Establishment and Modification 1. Analyze Workloads and Operations to Identify the Access Needs of All Users 3. Ensure that All System Users Have Been Assigned a Unique Identifier 5. Implement Access Control Procedures Using Selected Hardware and Software
Terminated users are disabled and all access removed promptly	Terminated users are disabled and all access removed promptly Area: IAM / JML HIPAA: 164.308(a)(3)(ii)(C) NIST CSF 2.0: PR.AA-01, PR.AA-05 NIST SP 800-53 r5: AC-2, PS-4 ISO 27001:2022: A.5.18, A.6.5 PCI DSS 4.0.1: 8.2.5 Risks: R02 Evidence: JML evidence (TERM-2026-0301); TC-04; TC-09 Test: TC-04; TC-09 Test result (2026-11-03): PASS (after CA-09)	Technical	akchrao@gmail.com	-	5. Establish Termination Procedures 9. Terminate Access if it is No Longer Required
Workforce Termination and Access Revocation	This control manages employee termination and access revocation across Microsoft Entra ID and Keycloak. It includes disabling terminated employee accounts, revoking sessions, removing application roles, manually disabling federated Keycloak accounts, and verifying access removal. Jeevan Smith's termination (TERM-2026-0301) demonstrated successful manual deprovisioning. However, automatic Keycloak account deactivation is not yet implemented, creating a residual IAM security risk.	Process	akchrao@gmail.com	-	5. Establish Termination Procedures
Alerts are raised and investigated	Alerts are raised and investigated Area: Monitoring / IR HIPAA: 164.308(a)(1)(ii)(D); 164.308(a)(6)(ii) NIST CSF 2.0: DE.AE-02, DE.AE-06	Technical	akchrao@gmail.com	-	7. Develop and Deploy the Information System Activity Review Process 9. Implement the Information System Activity Review and Audit Process Implementation Specification (Log-in

Name	Description	Category	Owner	ETA	Matching items
	NIST SP 800-53 r5: AU-6, SI-4 ISO 27001:2022: A.8.16 PCI DSS 4.0.1: 10.4.1 Risks: R03, R04 Evidence: identity_detections.csv; IR1 Tasks 2-3 Test: TC-05, TC-06, TC-07 Test result (2026-11-03): PASS (TC-05 after CA-10)				Monitoring) 5. Implement the Audit/System Activity Review Process
Control gaps are tracked to verified remediation	Control gaps are tracked to verified remediation Area: GRC HIPAA: 164.308(a)(8) NIST CSF 2.0: ID.IM-01, GV.OV-03 NIST SP 800-53 r5: CA-5, CA-7 ISO 27001:2022: Clause 10.2 PCI DSS 4.0.1: 12.4.2 Risks: R01-R05 Evidence: Corrective action tracker; exception register Test: TC-10 Test result (2026-11-03): PASS	Process	akchrao@gmail.com	-	3. Implement a Risk Management Program 3. Conduct Evaluation
Incidents are handled with a tested playbook	Incidents are handled with a tested playbook Area: Incident response HIPAA: 164.308(a)(6)(i)-(ii) NIST CSF 2.0: RS.MA-01, RS.AN-03 NIST SP 800-53 r5: IR-4, IR-5, IR-8 ISO 27001:2022: A.5.24-A.5.28 PCI DSS 4.0.1: 12.10.1 Risks: R03, R04 Evidence: IR1 Tasks 1-6; CAN-IR-PB-02 Test: IR1 Task 6 (34 checks) Test result (2026-11-03): PASS	Process	akchrao@gmail.com	-	3. Develop and Implement Policy and Procedures to Respond to and Report Security Incidents 4. Incorporate Post-Incident Analysis into Updates and Revisions
Role changes remove old access before new access is granted	Role changes remove old access before new access is granted Area: IAM / JML HIPAA: 164.308(a)(4)(ii)(C) NIST CSF 2.0: PR.AA-05 NIST SP 800-53 r5: AC-2, PS-5 ISO 27001:2022: A.5.18 PCI DSS 4.0.1: 7.2.4 Risks: R01 Evidence: JML evidence (CHG-2026-0201); TC-03 Test: TC-03 Test result (2026-11-03): PASS	Technical	akchrao@gmail.com	-	3. Implement Policies and Procedures for Access Establishment and Modification

Name	Description	Category	Owner	ETA	Matching items
Each application admits only approved job roles	Each application admits only approved job roles Area: IAM / application access HIPAA: 164.312(a)(1) NIST CSF 2.0: PR.AA-05 NIST SP 800-53 r5: AC-3 ISO 27001:2022: A.8.3 PCI DSS 4.0.1: 7.2.1 Risks: R01 Evidence: EV-13 app-gate verify; TC-02 Test: TC-02 Test result (2026-11-03): PASS	Technical	akchrao@gmail.com	-	5. Implement Access Control Procedures Using Selected Hardware and Software

Generated at 2026-11-04 18:03:23 UTC
Document ID 919117ba-6b58-4823-ad57-f7a45174e4df